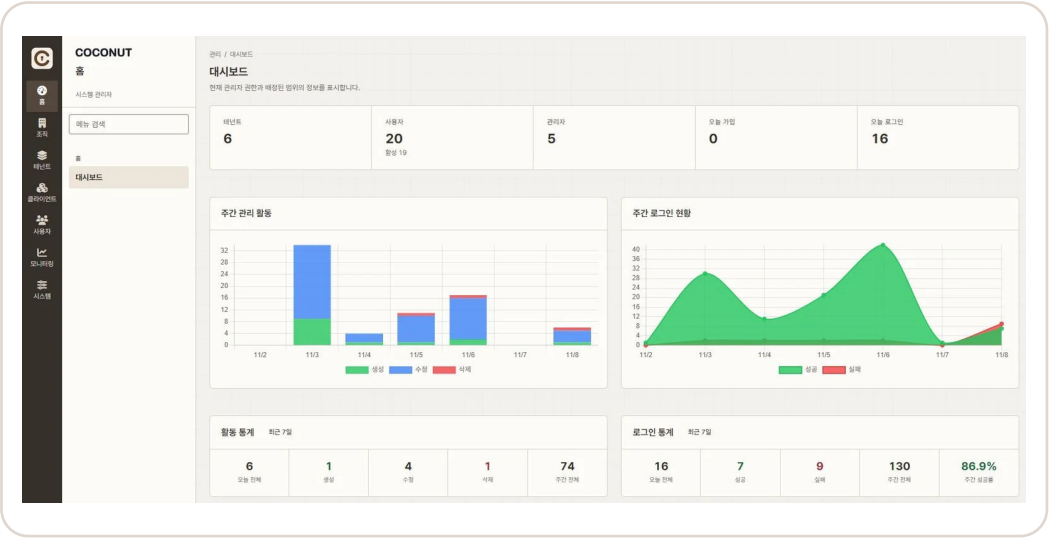
사람·서버·AI의 인증을 한곳에서.

COCONUT 제품설명서 - 최신 공개 기능과 관리자 화면

사용자 로그인과 서버 간 API 인증을 연결하는 OAuth2·OIDC 기반 통합 인증 솔루션입니다. MFA·토큰·세션·감사 기록을 관리하며, AI 도구의 접근 인증과 권한 통제도 개발·검증하고 있습니다.



인증은 COCONUT이,
업무 권한은 서비스가.

테넌트는 조직별 관리 범위, 클라이언트는 연결할 웹·앱·API를 뜻합니다.

OAuth2 · OIDC

표준 인가 서버

MFA 3종

SMS · 이메일 · OTP 앱

토큰 · 세션

발급부터 갱신 · 종료까지

멀티테넌트

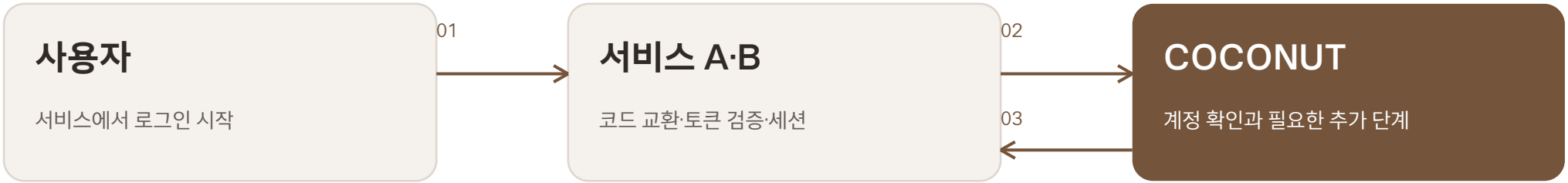
조직별 계정 · 관리 범위 구분

수록 내용: 사용자 로그인 · 서버 간 API · AI MCP · 콘솔 설정 · 보안·운영 · 연동과 도입 조건

화면은 2026년 11월 개발 환경 예시입니다. 표시된 수치·설정은 운영 실적이 아닙니다. AI MCP 인증은 개발 검증 중입니다.

한 번의 인증을 여러 서비스에 연결합니다.

사람이 코코넛에서 로그인하고, 각 서비스는 인증 결과를 확인해 자체 세션과 업무 권한을 적용합니다.



04 서비스 B도 유효한 인증 세션 확인 후 토큰 검증·자체 세션 생성

01 로그인 요청

연동 서비스가 표준 인가 요청으로 COCONUT 로그인 화면을 엽니다. 팝업 방식도 지원합니다.

02 계정과 추가 단계

계정을 확인하고 설정·기존 승인 상태에 따라 추가 인증과 접근 권한 동의를 진행합니다. 약관은 별도 절차입니다.

03 코드 교환·토큰 검증

인가 코드를 토큰으로 교환합니다. 서비스는 토큰을 검증하고 자체 세션과 업무 권한을 적용합니다.

04 인증 세션 재사용

같은 테넌트의 유효한 인증 세션이 있으면 재인증을 줄입니다. 서비스 B도 코드 교환·토큰 검증 후 자체 세션을 만듭니다.

같은 테넌트에서 인증 세션을 재사용하는 개념도입니다. 코드 교환 등 세부 요청은 생략했으며 재인증·동의 조건은 설정과 세션 상태에 따릅니다.

사용자 로그인 없이 서버의 신원을 확인합니다.

서버가 자신의 자격으로 토큰을 받아 API를 호출하는 Client Credentials 방식을 지원합니다. 자동 처리·시스템 간 조회처럼 사람이 로그인하지 않는 연동에 사용합니다.



01 서버 인증

호출 서버가 등록된 클라이언트 자격으로 코코넛에 토큰을 요청합니다.

02 토큰 발급

코코넛이 클라이언트와 허용된 요청 범위를 확인해 토큰을 발급합니다.

03 API 호출

호출 서버가 발급받은 토큰을 요청에 담아 대상 API를 호출합니다.

04 서비스 권한 확인

API 서버가 토큰과 호출 권한을 검증하고 허용된 업무를 처리합니다.

토큰 발급은 코코넛이, API의 업무·데이터 권한 검사는 해당 서비스가 담당합니다. 대상 API의 검증 방식과 연동 범위를 함께 구성합니다.

AI 연결에 사용자 인증과 동의를 적용합니다.

개발 검증 중 | AI 도구는 사용자 인증·동의를 거쳐 요청한 서비스에 접근합니다. 사용자 없이 서버가 호출하는 API 인증과 구분합니다.



01 AI 연결 요청

등록된 AI 도구가 접근할 서비스와 권한 범위를 요청합니다.

02 사용자 인증·동의

사용자가 코코넛에서 인증하고 요청된 접근 범위를 확인합니다.

03 접근 토큰 발급

AI 도구가 인가 코드를 교환하면 코코넛이 지정한 서비스와 허용된 권한 범위에 맞는 토큰을 발급합니다.

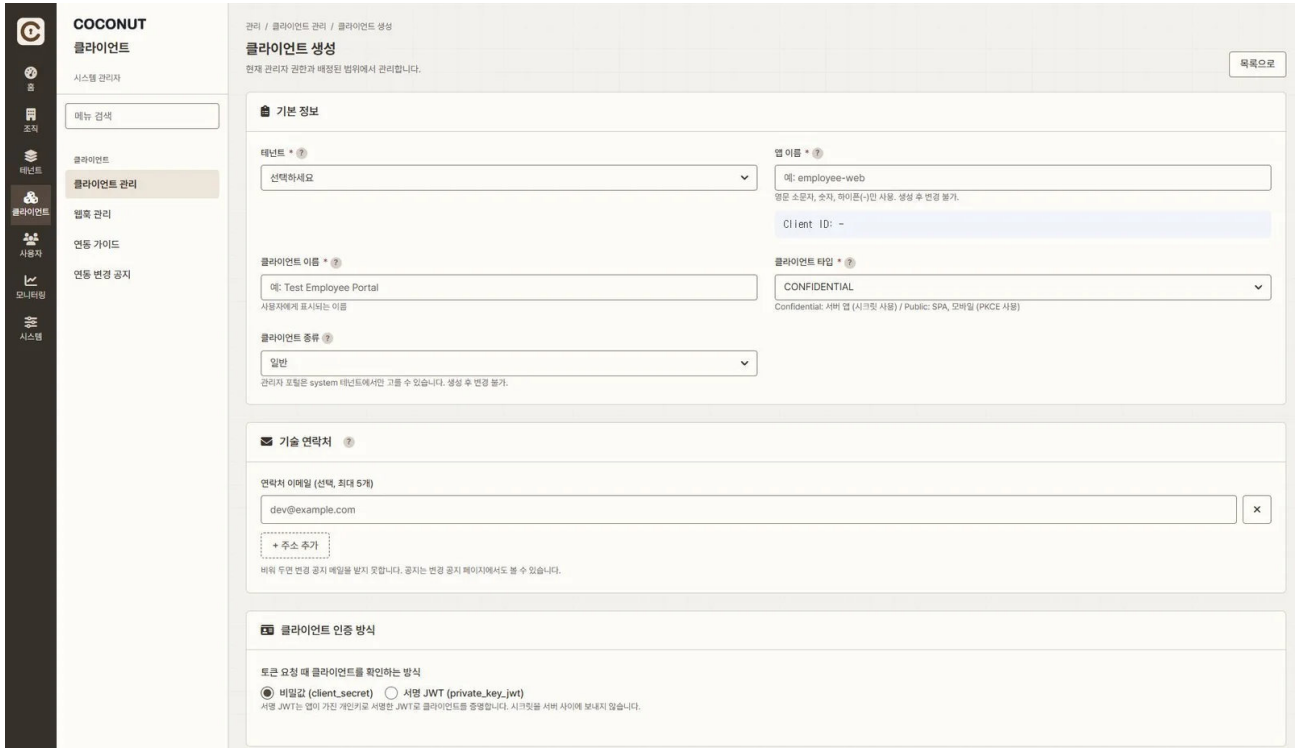
04 MCP 서버 검증

MCP 서버가 토큰·접근 상태·업무 권한을 확인하고 도구 요청을 처리합니다.

서비스 탐색과 인가 코드 교환의 세부 요청은 생략한 개념도입니다. 연결 권한을 철회한 뒤의 차단은 MCP 서버의 토큰 상태 확인·이벤트 반영과 함께 검증합니다.

서비스에 맞는 로그인 방식을 구성합니다.

웹·앱·API 서비스를 클라이언트로 등록하고 인증 방식과 스코프, 콜백 주소, 토큰 유효기간을 정합니다. 서버형(Confidential)과 공개형(Public)을 구분하고, 공개형에는 인가 코드 교환을 보호하는 PKCE를 필수 적용합니다.



01

서버형 · 공개형 클라이언트 구분

02

클라이언트 비밀값 · 서명 JWT 인증

03

인증 방식 · 토큰 · 콜백 주소 설정

비밀번호와 추가 인증을 서비스에 맞춥니다.

비밀번호 길이·복잡도·만료·재사용 제한과 MFA 필수 여부를 설정합니다. 로그인 시도 제한은 공통 기준으로 적용하며, 제한된 계정은 사용자 상세에서 확인하고 해제합니다.



01

서비스별 비밀번호 정책

02

MFA 필수 여부 · 사용자 방식 선택

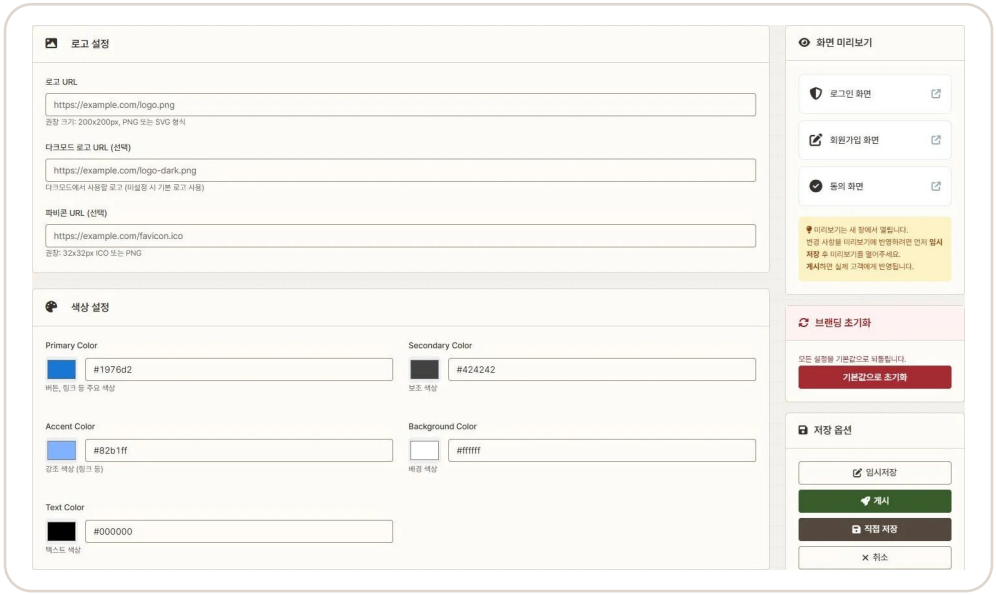
03

계정 상태 조회 · 잠금과 요청 제한 해제

서비스 브랜드와 동의 절차를 구분합니다.

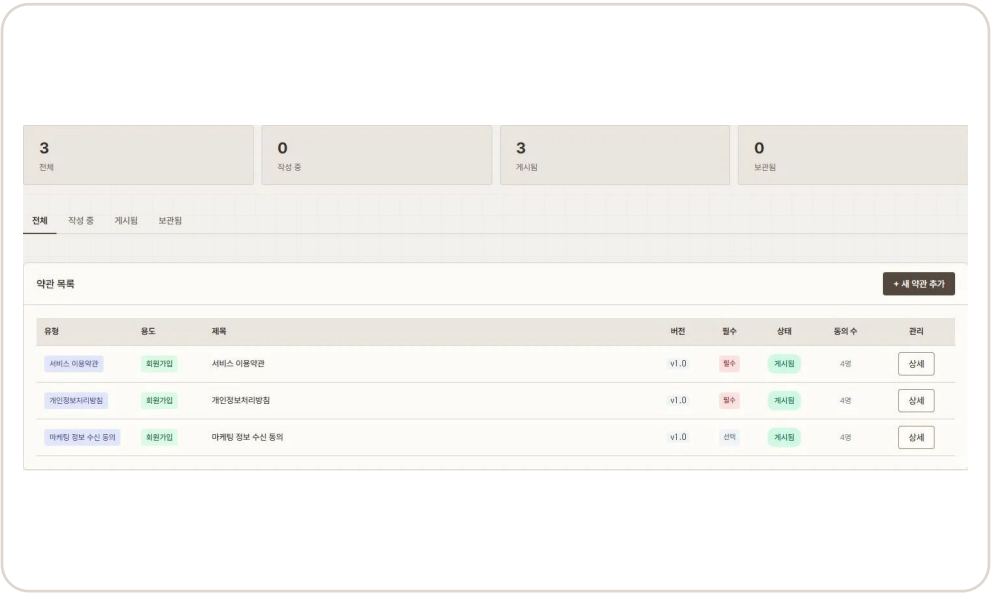
브랜딩과 약관 관리는 서로 다른 설정입니다. 약관 동의와 API 접근 권한 동의를 혼동하지 않습니다.

공통 인증에도 서비스의 브랜드를 담습니다.



로고·색상·글꼴과 로그인·회원가입 문구를 서비스별로 구성합니다. 미리보기와 임시저장·게시를 구분하고, 템플릿처럼 저장 시 바로 반영되는 항목은 따로 확인합니다.

약관 버전과 동의 상태를 함께 관리합니다.



서비스별 약관을 작성하고 버전·필수 여부·게시 상태와 동의 현황을 확인합니다. 회원가입 약관과 API 접근 권한에 대한 동의를 구분해 구성합니다.

공개 처리: 시험 서비스의 설정 영역만 사용했습니다. 실제 시크릿·연락처·접속 IP·계정 목록은 포함하지 않았습니다.

로그인 이후의 접근도 관리합니다.

계정·토큰·인증 세션을 관리하며, 서비스의 업무 권한과 외부 세션 종료는 서비스 측 연동으로 연결합니다.

계정·비밀번호 보호

로그인 시도 제한과 비밀번호 규칙을 적용하고, 계정 상태와 잠금을 관리합니다.

2단계 인증(MFA)

SMS·이메일·OTP 앱으로 추가 인증합니다. 서비스별 필수 여부와 신뢰 기기를 관리합니다.

토큰 갱신·재사용 통제

갱신 토큰 자동 교체를 기본 적용하고, 재사용 탐지와 인가 종료를 연결합니다.

인증 세션·접근 종료

인증 세션을 조회·종료하고, 외부 서비스에 계정·세션 이벤트를 전달합니다.

토큰 서명 키 교체

새 토큰의 서명 키와 기존 토큰의 검증 키를 구분해 교체합니다.

보안 감사 기록

로그인·계정 잠금·MFA·비밀번호·토큰 관련 보안 이벤트를 조회합니다.

운영 전에 함께 확인할 조건

외부 서비스 세션 종료는 서명된 웹훅 수신과 서비스 측 처리가 필요합니다. 장애 시 신규 로그인·토큰 갱신·기존 세션에 미치는 영향, 로그 보관·반출과 DB·서명 키의 백업·복구 기준을 함께 검토합니다.

기본 제공과 사전 검토 범위를 구분합니다.

기능 제공 상태와 서비스 측 연동·외부 계약·운영 검수는 구분해 확인합니다.

웹·앱 사용자 로그인	기본 제공	OAuth2·OIDC 기반 인가 코드 흐름과 PKCE(인가 코드 교환 보호). 앱 구조에 맞는 연결 작업이 필요합니다.
서버 간 API 인증	기본 제공 · API 연동 필요	Client Credentials로 서버의 신원을 확인하고 토큰을 발급합니다. 대상 API는 토큰과 허용된 업무 범위를 검증합니다.
계정·세션 이벤트	기본 제공 · 수신 개발 필요	서명된 웹훅을 제공합니다. 외부 서비스의 세션 종료와 상태 반영은 수신 서비스가 구현합니다.
문자·이메일·본인인증	외부 서비스 연동	LIME·NICE 연결을 구성합니다. 자격 정보, 네트워크 접근, 계약과 비용 범위를 확인합니다.
SAML · AD/LDAP · Entra ID	사전 검토 필요	기존 사내 계정·기업용 SSO와의 연결은 현재 인증 방식과 요구 프로토콜을 확인한 뒤 지원 범위를 안내합니다.
기존 회원·계정 자동 동기화	사전 검토 필요	회원 이전과 SCIM 등 계정 동기화는 기존 데이터 구조·연동 규격을 확인합니다. 자동 통합을 전제로 하지 않습니다.

Java 21 기반 애플리케이션 · MySQL 8.0 이상

Docker 이미지 기반 설치. 설치 위치와 운영 책임은 도입 시 협의. 사용자 수·최대 로그인 요청량·로그 보관량·DB 배치·이중화 구성에 따라 산정. 문자·이메일 발송은 LIME, 본인인증은 NICE 연동. 사용 기능에 맞춰 연결·계약 조건 확인.

시범 연동부터 단계적으로 전환합니다.

기존 회원 데이터와 계정·권한 연결, 검수 기준과 원복 조건을 먼저 정합니다.

01	**환경과 범위 확인**	사용자·서비스·기존 인증 체계와 설치 환경을 확인하고 공급·지원 범위를 정합니다.
02	**계정 전환 설계**	기존 회원 식별자와 업무 데이터 연결, 중복 계정, 비밀번호 이전·재설정 방식을 검토합니다.
03	**시범 서비스 연동**	대표 서비스에 로그인·토큰 검증·업무 권한·로그아웃·웹훅 처리를 연결합니다.
04	**운영 시나리오 검증**	정상 로그인과 계정 정지, 이벤트 누락, 장애, 백업·복구를 합의한 기준으로 확인합니다.
05	**단계적 전환·인계**	전환 순서와 원복 조건을 정하고, 운영 담당자에게 설정·점검·문의 절차를 인계합니다.

(주)포베리 | COCONUT 도입 상담

fourberry@fourberry.co.kr / 010-2755-0650

https://www.fourberry.co.kr/solutions/coconut/